

# OWASP Top 10:2025

Fielded, chunk-ready text for RAG ingestion

GENERATED\_DATE: 2026-01-29

## DOCUMENT\_METADATA

DOCUMENT\_TITLE: OWASP Top 10:2025 (Fielded RAG Format)  
DOCUMENT\_SCOPE: Top 10 categories only (A01:2025 to A10:2025)  
FORMAT\_GOAL: Consistent headings and chunk identifiers for reliable retrieval  
CONTENT\_RULES: No example-attack section, no reference section, plain-language only

## CATEGORY\_INDEX

INDEX\_ITEM: 01 | CATEGORY\_ID: A01:2025 | CATEGORY\_NAME: Broken Access Control  
INDEX\_ITEM: 02 | CATEGORY\_ID: A02:2025 | CATEGORY\_NAME: Security Misconfiguration  
INDEX\_ITEM: 03 | CATEGORY\_ID: A03:2025 | CATEGORY\_NAME: Software Supply Chain Failures  
INDEX\_ITEM: 04 | CATEGORY\_ID: A04:2025 | CATEGORY\_NAME: Cryptographic Failures  
INDEX\_ITEM: 05 | CATEGORY\_ID: A05:2025 | CATEGORY\_NAME: Injection  
INDEX\_ITEM: 06 | CATEGORY\_ID: A06:2025 | CATEGORY\_NAME: Insecure Design  
INDEX\_ITEM: 07 | CATEGORY\_ID: A07:2025 | CATEGORY\_NAME: Authentication Failures  
INDEX\_ITEM: 08 | CATEGORY\_ID: A08:2025 | CATEGORY\_NAME: Software or Data Integrity Failures  
INDEX\_ITEM: 09 | CATEGORY\_ID: A09:2025 | CATEGORY\_NAME: Security Logging and Alerting Failures  
INDEX\_ITEM: 10 | CATEGORY\_ID: A10:2025 | CATEGORY\_NAME: Mishandling of Exceptional Conditions

# A01:2025 - Broken Access Control

BEGIN\_CATEGORY: A01:2025

CATEGORY\_ID: A01:2025

CATEGORY\_NAME: Broken Access Control

## SECTION: Description

CHUNK\_ID: A01:2025.DESC.01

TEXT: Access control is the set of rules that decides who can do what in an application.

CHUNK\_ID: A01:2025.DESC.02

TEXT: Broken access control happens when those rules are missing, inconsistent, or can be bypassed, allowing users to read or change data and actions outside their permissions.

CHUNK\_ID: A01:2025.DESC.03

TEXT: This often shows up as users accessing other users' records, calling privileged API endpoints, or escalating to higher roles.

## SECTION: Common indicators

CHUNK\_ID: A01:2025.IND.01

TEXT: Requests are authorized only in the UI, not enforced on the server.

CHUNK\_ID: A01:2025.IND.02

TEXT: Object-level permissions (record ownership) are not checked for every read/write/delete.

CHUNK\_ID: A01:2025.IND.03

TEXT: Role checks exist but are inconsistent across endpoints and methods (GET vs POST/PUT/DELETE).

CHUNK\_ID: A01:2025.IND.04

TEXT: Tokens or metadata can be tampered with to gain privileges.

CHUNK\_ID: A01:2025.IND.05

TEXT: Cross-origin settings allow untrusted sites to call sensitive APIs.

## SECTION: Recommended controls

CHUNK\_ID: A01:2025.CTRL.01

TEXT: Enforce access control in server-side code for every request and every object.

CHUNK\_ID: A01:2025.CTRL.02

TEXT: Deny by default; explicitly allow only what is needed.

CHUNK\_ID: A01:2025.CTRL.03

TEXT: Centralize authorization logic and reuse it across the app and APIs.

CHUNK\_ID: A01:2025.CTRL.04

TEXT: Apply ownership checks for data objects (not just role checks).

CHUNK\_ID: A01:2025.CTRL.05

TEXT: Log repeated authorization failures and alert when patterns suggest abuse.

CHUNK\_ID: A01:2025.CTRL.06

TEXT: Rate-limit sensitive endpoints to reduce automated probing.

END\_CATEGORY: A01:2025

## A02:2025 - Security Misconfiguration

BEGIN\_CATEGORY: A02:2025

CATEGORY\_ID: A02:2025

CATEGORY\_NAME: Security Misconfiguration

### SECTION: Description

CHUNK\_ID: A02:2025.DESC.01

TEXT: Security misconfiguration is when systems, frameworks, cloud services, or application settings are left in insecure states.

CHUNK\_ID: A02:2025.DESC.02

TEXT: This creates openings such as unnecessary services, weak defaults, overly verbose errors, or missing protective headers.

CHUNK\_ID: A02:2025.DESC.03

TEXT: Because modern stacks are highly configurable, small mistakes can expose large parts of an environment.

### SECTION: Common indicators

CHUNK\_ID: A02:2025.IND.01

TEXT: Default accounts, passwords, or sample content exist in production.

CHUNK\_ID: A02:2025.IND.02

TEXT: Unneeded features, ports, services, or permissions are enabled.

CHUNK\_ID: A02:2025.IND.03

TEXT: Error messages reveal internal details (stack traces, versions, paths).

CHUNK\_ID: A02:2025.IND.04

TEXT: Security headers or platform security settings are missing or weak.

CHUNK\_ID: A02:2025.IND.05

TEXT: Environments drift (dev/test/prod are configured differently).

### SECTION: Recommended controls

CHUNK\_ID: A02:2025.CTRL.01

TEXT: Use automated, repeatable hardening to build and deploy environments.

CHUNK\_ID: A02:2025.CTRL.02

TEXT: Keep the platform minimal: remove unused components, samples, and accounts.

CHUNK\_ID: A02:2025.CTRL.03

TEXT: Standardize configuration across environments; use separate secrets per environment.

CHUNK\_ID: A02:2025.CTRL.04

TEXT: Review configuration and patch settings regularly as part of change management.

CHUNK\_ID: A02:2025.CTRL.05

TEXT: Segment components/tenants using network controls, containers, or cloud security groups.

CHUNK\_ID: A02:2025.CTRL.06

TEXT: Automatically verify configuration posture and reduce overly detailed error outputs.

END\_CATEGORY: A02:2025

## A03:2025 - Software Supply Chain Failures

BEGIN\_CATEGORY: A03:2025

CATEGORY\_ID: A03:2025

CATEGORY\_NAME: Software Supply Chain Failures

### SECTION: Description

CHUNK\_ID: A03:2025.DESC.01

TEXT: Software supply chain failures are compromises or breakdowns in how software is built, packaged, distributed, or updated.

CHUNK\_ID: A03:2025.DESC.02

TEXT: Risk can come from third-party dependencies, build tools, repositories, or delivery pipelines.

CHUNK\_ID: A03:2025.DESC.03

TEXT: A single compromised dependency or build step can affect many applications downstream.

### SECTION: Common indicators

CHUNK\_ID: A03:2025.IND.01

TEXT: No reliable inventory of direct and transitive dependencies.

CHUNK\_ID: A03:2025.IND.02

TEXT: Dependencies and platform components are outdated or unsupported.

CHUNK\_ID: A03:2025.IND.03

TEXT: Limited vulnerability monitoring and slow remediation of risky components.

CHUNK\_ID: A03:2025.IND.04

TEXT: Weak controls around source control, build systems, artifact stores, or developer tooling.

CHUNK\_ID: A03:2025.IND.05

TEXT: No separation of duties in releasing to production.

### SECTION: Recommended controls

CHUNK\_ID: A03:2025.CTRL.01

TEXT: Maintain a living inventory of components and dependencies, including transitive ones.

CHUNK\_ID: A03:2025.CTRL.02

TEXT: Remove unused dependencies and unnecessary features to reduce attack surface.

CHUNK\_ID: A03:2025.CTRL.03

TEXT: Monitor component security advisories and prioritize updates based on risk.

CHUNK\_ID: A03:2025.CTRL.04

TEXT: Use trusted sources and prefer signed packages; verify integrity of artifacts.

CHUNK\_ID: A03:2025.CTRL.05

TEXT: Harden source control, build pipelines, and artifact repositories with strong identity and least privilege.

CHUNK\_ID: A03:2025.CTRL.06

TEXT: Adopt change tracking for build/pipeline settings, repositories, and artifacts; use staged rollouts for

CHUNK\_ID: A03:2025.CTRL.07

TEXT: updates.

END\_CATEGORY: A03:2025

## A04:2025 - Cryptographic Failures

BEGIN\_CATEGORY: A04:2025

CATEGORY\_ID: A04:2025

CATEGORY\_NAME: Cryptographic Failures

### SECTION: Description

CHUNK\_ID: A04:2025.DESC.01

TEXT: Cryptographic failures occur when sensitive data is not properly protected in transit or at rest, or when encryption is applied incorrectly.

CHUNK\_ID: A04:2025.DESC.02

TEXT: Common problems include weak or outdated algorithms, poor key management, and missing enforcement of secure transport.

CHUNK\_ID: A04:2025.DESC.03

TEXT: The result is often exposure of credentials, personal data, financial data, or business secrets.

### SECTION: Common indicators

CHUNK\_ID: A04:2025.IND.01

TEXT: Sensitive data is sent over insecure channels or encryption is optional.

CHUNK\_ID: A04:2025.IND.02

TEXT: Encryption at rest is missing for high-value data stores.

CHUNK\_ID: A04:2025.IND.03

TEXT: Keys are hard-coded, reused too long, poorly rotated, or stored insecurely.

CHUNK\_ID: A04:2025.IND.04

TEXT: Certificate validation is weak or skipped in client or service communication.

CHUNK\_ID: A04:2025.IND.05

TEXT: Caches store sensitive responses longer than intended.

### SECTION: Recommended controls

CHUNK\_ID: A04:2025.CTRL.01

TEXT: Classify data and decide what must be encrypted in transit and at rest.

CHUNK\_ID: A04:2025.CTRL.02

TEXT: Use modern, well-vetted cryptographic libraries and configurations.

CHUNK\_ID: A04:2025.CTRL.03

TEXT: Protect keys using dedicated key management (prefer hardware or managed services).

CHUNK\_ID: A04:2025.CTRL.04



TEXT: Enforce strong transport security (e.g., modern TLS) and enable strict HTTPS policies.

CHUNK\_ID: A04:2025.CTRL.05

TEXT: Minimize retention of sensitive data; discard when no longer needed.

CHUNK\_ID: A04:2025.CTRL.06

TEXT: Disable caching for sensitive responses at all layers (CDN, server, application cache).

END\_CATEGORY: A04:2025

## A05:2025 - Injection

BEGIN\_CATEGORY: A05:2025

CATEGORY\_ID: A05:2025

CATEGORY\_NAME: Injection

### SECTION: Description

CHUNK\_ID: A05:2025.DESC.01

TEXT: Injection happens when untrusted input is interpreted as commands or structured data by a downstream component, such as a database, browser, operating system, or directory service.

CHUNK\_ID: A05:2025.DESC.02

TEXT: The attacker's input changes how the interpreter behaves.

CHUNK\_ID: A05:2025.DESC.03

TEXT: This can lead to data theft, data corruption, unauthorized actions, or remote code execution.

### SECTION: Common indicators

CHUNK\_ID: A05:2025.IND.01

TEXT: Inputs are concatenated into queries, commands, or templates.

CHUNK\_ID: A05:2025.IND.02

TEXT: Dynamic queries use string building instead of safe parameter binding.

CHUNK\_ID: A05:2025.IND.03

TEXT: Context-specific escaping is missing (HTML, SQL, shell, LDAP, etc.).

CHUNK\_ID: A05:2025.IND.04

TEXT: Untrusted input reaches interpreters through ORMs, query builders, or templating engines without strict

CHUNK\_ID: A05:2025.IND.05

TEXT: controls.

### SECTION: Recommended controls

CHUNK\_ID: A05:2025.CTRL.01

TEXT: Use parameterized queries or safe APIs for interpreters (SQL, NoSQL, OS commands).

CHUNK\_ID: A05:2025.CTRL.02

TEXT: Validate input with allow-lists when possible; constrain types, length, and format.

CHUNK\_ID: A05:2025.CTRL.03

TEXT: Apply context-aware output encoding/escaping at the last possible moment.

CHUNK\_ID: A05:2025.CTRL.04

TEXT: Use secure templating and avoid evaluating user-controlled expressions.

CHUNK\_ID: A05:2025.CTRL.05

TEXT: Adopt automated testing and code review patterns focused on injection risks.

END\_CATEGORY: A05:2025

## A06:2025 - Insecure Design

BEGIN\_CATEGORY: A06:2025

CATEGORY\_ID: A06:2025

CATEGORY\_NAME: Insecure Design

### SECTION: Description

CHUNK\_ID: A06:2025.DESC.01

TEXT: Insecure design is when required security controls are missing or ineffective at the architecture and requirements level.

CHUNK\_ID: A06:2025.DESC.02

TEXT: The system may work as intended but is not designed to resist realistic threats.

CHUNK\_ID: A06:2025.DESC.03

TEXT: A secure implementation cannot fully fix a design that never defined the needed safeguards.

CHUNK\_ID: A06:2025.DESC.04

TEXT: Subsections Requirements and resource management Define security requirements alongside business requirements (confidentiality, integrity, availability, authenticity).

CHUNK\_ID: A06:2025.DESC.05

TEXT: Consider exposure, tenant separation needs, and the expected safe and failure states of critical flows.

CHUNK\_ID: A06:2025.DESC.06

TEXT: Secure design Use a threat-aware design process.

CHUNK\_ID: A06:2025.DESC.07

TEXT: Model key data flows and trust boundaries, challenge assumptions, and document how controls will enforce correct behavior and safe failure states.

CHUNK\_ID: A06:2025.DESC.08

TEXT: Secure development lifecycle Build security into the development lifecycle through patterns, shared components, reviews, testing, and learning from incidents.

CHUNK\_ID: A06:2025.DESC.09

TEXT: Engage security expertise early and continuously.

### SECTION: Common indicators

CHUNK\_ID: A06:2025.IND.01

TEXT: Security requirements are not defined for critical features and data flows.

CHUNK\_ID: A06:2025.IND.02

TEXT: Threat modeling is not performed for high-risk areas (auth, access control, business logic).

CHUNK\_ID: A06:2025.IND.03

TEXT: Design decisions rely on assumptions that are not validated or documented.

CHUNK\_ID: A06:2025.IND.04

TEXT: No plan exists for secure failure states, abuse cases, or tenant isolation needs.

CHUNK\_ID: A06:2025.IND.05

TEXT: Security is treated as an implementation task late in development.

## **SECTION: Recommended controls**

CHUNK\_ID: A06:2025.CTRL.01

TEXT: Use a secure development lifecycle to design and review security and privacy controls.

CHUNK\_ID: A06:2025.CTRL.02

TEXT: Standardize secure patterns and shared components ("paved road" building blocks).

CHUNK\_ID: A06:2025.CTRL.03

TEXT: Threat model critical areas such as authentication, authorization, business logic, and key flows.

CHUNK\_ID: A06:2025.CTRL.04

TEXT: Write tests for critical flows based on the threat model, including misuse cases.

CHUNK\_ID: A06:2025.CTRL.05

TEXT: Segment tiers and tenants by design when exposure requires it.

END\_CATEGORY: A06:2025

## A07:2025 - Authentication Failures

BEGIN\_CATEGORY: A07:2025

CATEGORY\_ID: A07:2025

CATEGORY\_NAME: Authentication Failures

### SECTION: Description

CHUNK\_ID: A07:2025.DESC.01

TEXT: Authentication failures occur when attackers can impersonate users or take over accounts because login, session handling, or credential recovery is weak.

CHUNK\_ID: A07:2025.DESC.02

TEXT: Automated attacks and credential reuse are common drivers.

CHUNK\_ID: A07:2025.DESC.03

TEXT: This can lead to account takeover, privilege abuse, and downstream data exposure.

### SECTION: Common indicators

CHUNK\_ID: A07:2025.IND.01

TEXT: No protection against automated login attempts or credential stuffing.

CHUNK\_ID: A07:2025.IND.02

TEXT: Weak passwords are allowed, or breached passwords are accepted.

CHUNK\_ID: A07:2025.IND.03

TEXT: Default or shared credentials exist in deployed systems.

CHUNK\_ID: A07:2025.IND.04

TEXT: Multi-factor authentication is missing where risk warrants it.

CHUNK\_ID: A07:2025.IND.05

TEXT: Sessions are exposed or not invalidated correctly (e.g., after logout or inactivity).

### SECTION: Recommended controls

CHUNK\_ID: A07:2025.CTRL.01

TEXT: Use multi-factor authentication where possible, especially for high-risk actions and privileged users.

CHUNK\_ID: A07:2025.CTRL.02

TEXT: Rate-limit and lock out or challenge suspicious authentication traffic.

CHUNK\_ID: A07:2025.CTRL.03

TEXT: Encourage password managers; enforce strong password policies and checks against

CHUNK\_ID: A07:2025.CTRL.04

TEXT: known-breached passwords.

CHUNK\_ID: A07:2025.CTRL.05

TEXT: Never deploy default credentials; require unique admin credentials and secure bootstrap processes.

CHUNK\_ID: A07:2025.CTRL.06

TEXT: Secure session management: protect tokens, rotate when needed, and invalidate on logout/inactivity.

END\_CATEGORY: A07:2025

## A08:2025 - Software or Data Integrity Failures

BEGIN\_CATEGORY: A08:2025

CATEGORY\_ID: A08:2025

CATEGORY\_NAME: Software or Data Integrity Failures

### SECTION: Description

CHUNK\_ID: A08:2025.DESC.01

TEXT: Software or data integrity failures happen when applications treat untrusted code, updates, configurations, or data as trustworthy without verifying integrity.

CHUNK\_ID: A08:2025.DESC.02

TEXT: This includes unsafe plugin loading, unverified artifacts, insecure pipelines, and unsafe serialization.

CHUNK\_ID: A08:2025.DESC.03

TEXT: Attackers may tamper with artifacts or data so the application executes or trusts something it should not.

### SECTION: Common indicators

CHUNK\_ID: A08:2025.IND.01

TEXT: Artifacts or updates are consumed without signature or integrity verification.

CHUNK\_ID: A08:2025.IND.02

TEXT: Dependencies can be pulled from untrusted or unmanaged repositories.

CHUNK\_ID: A08:2025.IND.03

TEXT: Code/config changes flow into builds and deployments without review or controls.

CHUNK\_ID: A08:2025.IND.04

TEXT: Pipelines and build environments have weak access control or separation.

CHUNK\_ID: A08:2025.IND.05

TEXT: Serialized data from clients is accepted and used without tamper detection.

### SECTION: Recommended controls

CHUNK\_ID: A08:2025.CTRL.01

TEXT: Verify code and artifacts using signatures or equivalent integrity checks.

CHUNK\_ID: A08:2025.CTRL.02

TEXT: Restrict dependencies to trusted repositories; consider an internal vetted repository for higher-risk

CHUNK\_ID: A08:2025.CTRL.03



TEXT: environments.

CHUNK\_ID: A08:2025.CTRL.04

TEXT: Require review and approval for code and configuration changes affecting builds and deployments.

CHUNK\_ID: A08:2025.CTRL.05

TEXT: Harden CI/CD access and segregation to protect the integrity of what gets built and released.

CHUNK\_ID: A08:2025.CTRL.06

TEXT: Do not trust serialized data from clients without integrity protection and strict validation.

END\_CATEGORY: A08:2025

## A09:2025 - Security Logging and Alerting Failures

BEGIN\_CATEGORY: A09:2025

CATEGORY\_ID: A09:2025

CATEGORY\_NAME: Security Logging and Alerting Failures

### SECTION: Description

CHUNK\_ID: A09:2025.DESC.01

TEXT: When logging, monitoring, and alerting are insufficient, attacks can go undetected and incident response becomes slow or ineffective.

CHUNK\_ID: A09:2025.DESC.02

TEXT: Logging must capture security-relevant events and alerting must reliably route urgent signals to responders.

CHUNK\_ID: A09:2025.DESC.03

TEXT: Good logs without actionable alerting still leave organizations blind during active incidents.

### SECTION: Common indicators

CHUNK\_ID: A09:2025.IND.01

TEXT: Security events are not logged consistently (e.g., failed logins, authorization failures).

CHUNK\_ID: A09:2025.IND.02

TEXT: Logs lack context needed to investigate (user, source, action, result).

CHUNK\_ID: A09:2025.IND.03

TEXT: Log integrity is weak; attackers can tamper with or delete logs.

CHUNK\_ID: A09:2025.IND.04

TEXT: Logs are not monitored, or alerts are noisy and ignored.

CHUNK\_ID: A09:2025.IND.05

TEXT: Audit trails for important transactions are missing.

### SECTION: Recommended controls

CHUNK\_ID: A09:2025.CTRL.01

TEXT: Log authentication, authorization, and validation failures with enough context for investigation.

CHUNK\_ID: A09:2025.CTRL.02

TEXT: Log both success and failure of security controls where it matters (not only successes).

CHUNK\_ID: A09:2025.CTRL.03

TEXT: Protect logs from tampering; centralize and retain them for forensic needs.

CHUNK\_ID: A09:2025.CTRL.04

TEXT: Encode log data safely to prevent log injection and downstream parsing issues.

CHUNK\_ID: A09:2025.CTRL.05

TEXT: Define alerting use-cases and response playbooks; tune to reduce false positives.

END\_CATEGORY: A09:2025

# A10:2025 - Mishandling of Exceptional Conditions

BEGIN\_CATEGORY: A10:2025

CATEGORY\_ID: A10:2025

CATEGORY\_NAME: Mishandling of Exceptional Conditions

## SECTION: Description

CHUNK\_ID: A10:2025.DESC.01

TEXT: Exceptional conditions are unexpected states such as invalid inputs, missing parameters, resource exhaustion, network failures, or partial transactions.

CHUNK\_ID: A10:2025.DESC.02

TEXT: Mishandling happens when the system does not prevent, detect, or respond safely to these conditions.

CHUNK\_ID: A10:2025.DESC.03

TEXT: Poor error handling can cause crashes, inconsistent state, information leakage, and security bypasses ("fail open").

## SECTION: Common indicators

CHUNK\_ID: A10:2025.IND.01

TEXT: Errors are handled only globally and not near the source of failure.

CHUNK\_ID: A10:2025.IND.02

TEXT: Transactions can partially complete and leave inconsistent state.

CHUNK\_ID: A10:2025.IND.03

TEXT: Errors leak sensitive details or change behavior in unsafe ways.

CHUNK\_ID: A10:2025.IND.04

TEXT: Unhandled exceptions cause crashes or unpredictable flows.

CHUNK\_ID: A10:2025.IND.05

TEXT: Repeated errors are not monitored or alerted on.

## SECTION: Recommended controls

CHUNK\_ID: A10:2025.CTRL.01

TEXT: Handle exceptions close to where they occur; validate inputs early and consistently.

CHUNK\_ID: A10:2025.CTRL.02

TEXT: Fail closed: on error, roll back partial work and return to a safe state.

CHUNK\_ID: A10:2025.CTRL.03

TEXT: Return user-safe error messages; log detailed diagnostics securely for operators.

CHUNK\_ID: A10:2025.CTRL.04

TEXT: Add a global exception handler as a safety net for missed cases.

CHUNK\_ID: A10:2025.CTRL.05

TEXT: Monitor for recurring error patterns and automate responses when abuse is suspected.

END\_CATEGORY: A10:2025